

Sicherstellung der Datenintegrität und Compliance: Eine umfassende Analyse von Kontrollmechanismen und Audit-Prozessen im Backup- und Archivierungsmanagement

Autor: Mevluet Polat

Zusammenfassung

Die rasant wachsende Abhängigkeit moderner Organisationen von digitalen Informationssystemen macht die Sicherung und Archivierung von Daten zu einem der kritischsten Prozesse in der IT-Governance. Der vorliegende Artikel analysiert systematisch die notwendigen Kontrollmechanismen – sowohl automatisierter als auch manueller Natur –, die zur Sicherstellung der Funktion von Backup- und Archivierungssystemen erforderlich sind. Darüber hinaus werden Eskalationsprozesse beleuchtet und die methodischen Grundlagen von Audits zur Prüfung der Konzept Einhaltung detailliert dargelegt. Ein besonderer Fokus liegt auf der Erfüllung regulatorischer Anforderungen, insbesondere im Kontext des Schweizer Datenschutzgesetzes (nDSG) und branchenspezifischer Vorgaben.

1. Einleitung

In der heutigen digitalen Ökonomie stellen Daten das wertvollste Gut eines Unternehmens dar. Der Verlust, die Beschädigung oder die unerlaubte Manipulation dieser Daten kann zu existenziellen Krisen führen. Aus diesem Grund reicht es längst nicht mehr aus, lediglich Backup-Systeme zu installieren; vielmehr muss durch ein engmaschiges Netz an Kontrollen und Überprüfungsprozessen kontinuierlich sichergestellt werden, dass diese Systeme im Ernstfall auch fehlerfrei funktionieren. Ein ganzheitliches Backup- und Archivierungskonzept stützt sich dabei auf technische (automatisierte) und organisatorische (manuelle) Säulen, die durch strenge Eskalations- und Auditprozesse flankiert werden. Dieser Artikel dekonstruiert diese Mechanismen und veranschaulicht sie anhand praxisnaher Beispiele.

2. Automatisierte Kontrollen zur Sicherstellung der Funktion

Der erste Verteidigungswall gegen Datenverlust ist die Automatisierung von Kontrollprozessen

(Folie 14). Da moderne IT-Umgebungen täglich Terabytes oder gar Petabytes an Daten verarbeiten, ist eine manuelle Überwachung jedes einzelnen Sicherungsvorgangs unmöglich geworden. Automatisierte Kontrollen reduzieren die Fehleranfälligkeit des Menschen ("Human Error") und sorgen für eine lückenlose Echtzeitüberwachung.

2.1 Backup-Monitoring und Jobprotokollierung

Das automatisierte **Backup-Monitoring** prüft täglich und ohne menschliches Zutun, ob alle geplanten Backup-Jobs erfolgreich, teilweise erfolgreich (mit Warnungen) oder fehlerhaft abgeschlossen wurden. Eng damit verknüpft ist die **Jobprotokollierung**, bei der alle Ergebnisse systematisch archiviert werden, um historische Auswertungen zu ermöglichen.

- **Beispiel:** Ein Unternehmen nutzt eine zentrale Backup-Software, die nachts 500 virtuelle Server sichert. Das Monitoring-System aggregiert die Ergebnisse auf einem Dashboard. Fällt der Backup-Job für den zentralen ERP-Server (Enterprise Resource Planning) aus, weil das Netzwerk kurzzeitig unterbrochen war, verzeichnet das Protokoll diesen Abbruch. Anstatt dass ein Administrator am nächsten Morgen 500 Logfiles lesen muss, präsentiert das Dashboard sofort einen roten Indikator für den betroffenen Server.

2.2 Integritätsprüfung

Eine der wichtigsten, aber oft unterschätzten Funktionen ist die **Integritätsprüfung**. Ein Backup ist wertlos, wenn die gesicherten Daten korrupt sind. Durch die Berechnung von Prüfsummen (Checksums) und kryptografischen Hash-Werten (z. B. SHA-256) beim Schreiben der Daten und den erneuten Abgleich beim Lesen verifiziert das Speichersystem automatisch die Unversehrtheit.

- **Beispiel:** Ransomware-Attacken zielen heutzutage oft darauf ab, Daten schleichend zu verschlüsseln, bevor das System blockiert wird. Wenn ein Backup-System Hash-Werte nutzt, kann es feststellen, dass sich die Struktur einer ansonsten kaum veränderten Datenbankdatei plötzlich auf Blockebene massiv geändert hat (weil sie verschlüsselt wurde). Das System schlägt Alarm, da die Integrität der Originaldaten fraglich ist, bevor dieses fehlerhafte Backup ältere, gesunde Backups überschreibt.

2.3 Kapazitätsüberwachung und Alarmierung

Datenmengen wachsen kontinuierlich. Die **Kapazitätsüberwachung** dient dazu, drohende Engpässe auf den Backup-Speichermedien (z. B. Disk-Arrays oder Cloud-Repositories) frühzeitig zu erkennen. Die automatische **Alarmierung** sorgt dafür, dass bei Fehlern oder Speicherknappheit sofort Benachrichtigungen an die zuständigen Stellen abgesetzt werden.

- **Beispiel:** Das Backup-Storage-System erkennt, dass der verbleibende Speicherplatz bei gleichbleibendem Datenwachstum in fünf Tagen aufgebraucht sein wird. Es generiert automatisch ein Ticket im IT-Service-Management-System (ITSM) und sendet eine E-Mail an das Storage-Team. So können neue Festplatten bestellt oder alte Daten gemäss

Aufbewahrungsrichtlinien bereinigt werden, bevor ein nächtlicher Backup-Job wegen "Disk Full" fehlschlägt.

3. Manuelle Kontrollen als unverzichtbare Ergänzung

Trotz aller Automatisierung bleiben **manuelle Kontrollen** (Folie 15) essenziell. Automatisierte Systeme prüfen in der Regel nur das, wofür sie programmiert wurden. Die menschliche Verifikation schliesst Lücken, die durch logische Fehler im Systemdesign oder schleichende Fehlkonfigurationen entstehen.

3.1 Protokollkontrolle und Stichprobentests (Restore-Tests)

Bei der **Protokollkontrolle** prüfen verantwortliche Personen regelmässig (z. B. wöchentlich) die automatisierten Reports auf Auffälligkeiten, die ein Algorithmus möglicherweise als "erfolgreich" bewertet hat, die aber für einen Experten unlogisch erscheinen (z. B. wenn ein Backup plötzlich in 5 Minuten statt in 2 Stunden durchläuft, was auf nicht erfasste Daten hindeutet). Noch wichtiger sind die **Stichprobentests**. Ein Backup ist erst dann ein verifiziertes Backup, wenn ein erfolgreicher Restore (Wiederherstellung) nachgewiesen wurde.

- **Beispiel:** Ein Administrator führt einen unangekündigten Stichprobentest durch. Er wählt eine Dateiablage der Personalabteilung aus dem gestrigen Backup und versucht, diese in einer isolierten Testumgebung (Sandbox) wiederherzustellen. Dabei stellt er fest, dass die Wiederherstellung zwar technisch funktioniert, die Dateien aber nicht geöffnet werden können, da der Verschlüsselungs-Key des Fileservers im Backup-Konzept nicht mitgesichert wurde. Dieser fatale Konzeptfehler konnte nur durch den manuellen Test aufgedeckt werden.

3.2 Medieninspektion, Konfigurations- und Berechtigungsreview

Physische **Medieninspektionen** sind besonders bei Tape-Backups (Magnetbändern) relevant. Bänder verschleissen, können durch Staub oder Magnetfelder beschädigt werden. Gleichzeitig müssen durch **Konfigurationsreviews** die Einstellungen der Software periodisch auf Konzeptkonformität geprüft werden. Ein **Berechtigungsreview** stellt sicher, dass nur autorisiertes Personal Backups löschen oder verändern kann.

- **Beispiel Berechtigungsreview:** Ein Mitarbeiter der IT-Infrastruktur hat das Unternehmen verlassen. Beim vierteljährlichen Berechtigungsreview der Backup-Software stellt der Chief Information Security Officer (CISO) fest, dass der Account des ehemaligen Mitarbeiters noch aktiv ist und über Löschrechte für die Cloud-Backups verfügt. Diese Rechte werden sofort entzogen, um das Risiko eines Insider-Angriffs oder böswilligen Datenverlusts (Sabotage) abzuwenden.

4. Spezifische Kontrollen bei der Archivierung

Archivierung unterscheidet sich fundamental von einem Backup. Während ein Backup der

kurzfristigen Wiederherstellung nach einem Ausfall dient, sichert die Archivierung (Folie 16) die unveränderbare Langzeitaufbewahrung von Daten (oft über 10 Jahre oder länger), meist aus regulatorischen Gründen.

4.1 Archivintegrität und Migrationsplanung

Da Archivdaten oft jahrelang nicht angerührt werden, muss die **Archivintegrität** in definierten Abständen proaktiv auf Lesbarkeit geprüft werden. Eng damit verbunden ist die **Migrationsplanung**. Hardware und Software-Formate veralten. Archivmedien müssen rechtzeitig auf neue Technologien migriert werden, bevor das Lesegerät nicht mehr existiert.

- **Beispiel Migrationsplanung:** Ein Spital archiviert Patientenakten auf optischen Medien (CD-ROMs/DVDs) aus dem Jahr 2005. Da moderne Server heute keine entsprechenden Laufwerke mehr besitzen und optische Medien nach 10-15 Jahren degradieren ("CD-Rot"), plant das Spital ein Migrationsprojekt. Die Daten werden systematisch ausgelesen, die Integrität verifiziert und auf ein modernes, redundantes WORM-Storage-System (Write Once, Read Many) in der Cloud migriert.

4.2 Indexprüfung, Aufbewahrungs- und Löschkontrolle

Um in Terabytes von Archivdaten ein spezifisches Dokument (z. B. für einen Rechtsstreit) zu finden, ist ein korrekter Index zwingend. Die **Indexprüfung** stellt dessen Vollständigkeit sicher. Die **Aufbewahrungskontrolle** dokumentiert die Einhaltung gesetzlicher Fristen, während die **Löschkontrolle** sicherstellt, dass Daten nach Ablauf dieser Fristen datenschutzkonform, vollständig und nachweisbar vernichtet werden.

- **Beispiel Löschkontrolle:** Gemäss dem Schweizerischen Obligationenrecht (OR) müssen Geschäftsbücher 10 Jahre aufbewahrt werden. Nach Ablauf des 10. Jahres vom 31. Dezember 2013 führt das Finanzinstitut im Januar 2024 eine kontrollierte Löschung der Archive aus 2013 durch. Ein Algorithmus überschreibt die Daten mehrfach (Shredding). Der Vorgang wird durch das System kryptografisch zertifiziert. Dieses Zertifikat dient im Audit als Beweis, dass keine Alt-Daten unnötig (und somit im Konflikt mit der Datensparsamkeit des Datenschutzes) weiter gespeichert wurden.

5. Eskalations- und Meldeprozesse

Fehler im Backup-Betrieb sind unvermeidlich (Hardware-Defekte, Netzwerk-Timeouts). Entscheidend ist der methodische Umgang damit (Folie 17). Ein strukturiertes Incident Management verhindert, dass Fehler ignoriert werden.

5.1 Eskalationsstufen und Reaktionszeiten

Nicht jeder Fehler ist gleich schlimm. **Eskalationsstufen** definieren, wer wann informiert wird. Verbindliche **Reaktionszeiten** (Service Level Agreements, SLAs) legen fest, wie schnell gehandelt werden muss.

- **Beispiel:** Das Backup eines unkritischen internen Wiki-Servers schlägt fehl (Schweregrad 3 – gering). Der 1st-Level-Support erhält ein Ticket mit einer Reaktionszeit von 24 Stunden. Schlägt hingegen das Backup der zentralen Transaktionsdatenbank der Bank fehl (Schweregrad 1 – kritisch), wird sofort eine SMS-Alarmierung an den Pikett-Dienst (Bereitschaftsdienst) ausgelöst, mit der Vorgabe, innerhalb von 15 Minuten mit der Fehlerbehebung zu beginnen.

5.2 Meldepflicht, Nachverfolgung und Lessons Learned

Kritische Ausfälle, die die Geschäftskontinuität gefährden, unterliegen einer strengen **Meldepflicht** gegenüber der Unternehmensleitung (C-Level). Jeder Vorfall erfordert eine lückenlose **Nachverfolgung** (Tracking). Im Rahmen von **Lessons Learned** (Post-Mortem-Analyse) wird ermittelt, wie der Fehler künftig vermieden werden kann.

- **Beispiel Lessons Learned:** Ein Storage-Ausfall führte dazu, dass drei Tage lang keine Backups erstellt wurden. Die Analyse ergab, dass das Alarmierungssystem falsch konfiguriert war und E-Mails im Spam-Filter landeten. Als "Lesson Learned" wird das Konzept dahingehend angepasst, dass kritische Warnungen künftig nicht mehr nur per E-Mail, sondern zusätzlich über eine API an den Messenger-Dienst des Operations-Teams (z. B. Microsoft Teams oder Slack) und per Pager gesendet werden.

6. Prüfung der Konzepteinhaltung: Audits

Alle bisher genannten Kontrollen sind operative Tätigkeiten. Um sicherzustellen, dass diese operativen Tätigkeiten auch wirklich gemäss den strategischen Vorgaben und regelkonform ausgeführt werden, bedarf es formaler Überprüfungen: den Audits (Folie 18 & 19).

6.1 Audit-Grundlagen und Auditarten

Ein **Audit** ist eine formelle, systematische und unabhängige Überprüfung. Man unterscheidet **interne Audits** (durchgeführt von einer firmeninternen, aber abteilungsunabhängigen Stelle, z. B. der internen Revision) und **externe Audits** (durch unabhängige Prüfgesellschaften wie KPMG, PwC oder spezialisierte Zertifizierer). Sie ergänzen sich gegenseitig.

- **Beispiel:** Ein Unternehmen bereitet sich auf eine ISO 27001 Zertifizierung vor. Das interne Qualitätsmanagement führt ein internes Audit durch, um blinde Flecken im Backup-Konzept zu finden. Sechs Monate später kommt der externe Auditor. Da der externe Prüfer nicht in die betrieblichen Abläufe verstrickt ist, bringt er eine objektive Aussensicht mit und stellt fest, dass zwar alle Backups laufen, aber die physische Zugangskontrolle zum Bandarchiv im Keller mangelhaft ist.

6.2 Auditfrequenz, Auditumfang und Prüfbereiche

Die **Auditfrequenz** richtet sich nach der Kritikalität. Core-Systeme werden jährlich geprüft. Der **Auditumfang** wird zwingend vorab definiert. Im Audit werden diverse **Prüfbereiche** untersucht:

Die **Konzeptaktualität** (Passt das Dokument noch zur Server-Landschaft?), die **Konfigurationskonformität** (Sind die Jobs so eingestellt, wie das Konzept es verlangt?), die **Protokollvollständigkeit** und vor allem der **Testnachweis** für Restores. Auch **Berechtigungen** stehen auf dem Prüfstand.

- **Beispiel Testnachweis & Konzeptaktualität:** Der Auditor verlangt die Einsicht in die Dokumentation der letzten fünf Restore-Tests. Die Administratoren können jedoch nur drei nachweisen, da "die Zeit fehlte". Gleichzeitig stellt der Auditor bei der Prüfung der Konzeptaktualität fest, dass das Backup-Konzept vor drei Jahren geschrieben wurde. In der Zwischenzeit hat das Unternehmen Microsoft 365 eingeführt. Die Cloud-Daten aus Exchange Online und SharePoint werden im Konzept überhaupt nicht erwähnt und ergo auch nicht dediziert gesichert. Dies führt zu einer schweren Abweichung im **Auditbericht**.

7. Umgang mit Audit-Feststellungen

Ein Audit endet nicht mit dem Überreichen eines Berichts. Der Mehrwert entsteht erst im geregelten Umgang mit den aufgedeckten Schwachstellen (Feststellungen oder "Findings") (Folie 20).

7.1 Klassifizierung und Sofortmassnahmen

Jede Audit-Feststellung wird **klassifiziert**. Dies geschieht meist in den Kategorien *kritisch* (unmittelbare Gefährdung der Unternehmensexistenz oder massive Gesetzesverstöße), *wesentlich* (hohes Risiko, bedarf zeitnaher Lösung) und *geringfügig* (Verbesserungspotenzial, formale Mängel). Bei kritischen Mängeln müssen unverzüglich **Sofortmassnahmen** (Mitigation) ergriffen werden.

- **Beispiel Klassifizierung:**
 - *Kritisch:* Es existiert kein Offline-Backup oder Immutable-Backup (Schutz vor Ransomware) für die Kundendatenbank. (Sofortmassnahme: Manuelles Ziehen eines Backups auf eine externe, vom Netz getrennte Festplatte am selben Tag).
 - *Wesentlich:* Die Restore-Tests wurden nur jährlich statt halbjährlich durchgeführt.
 - *Geringfügig:* Im Backup-Konzept sind zwei Abteilungsnamen veraltet, da sich das Organigramm geändert hat.

7.2 Massnahmenplan und Umsetzungskontrolle

Für alle Feststellungen muss das Management einen **Massnahmenplan** (CAPA - Corrective and Preventive Actions) erstellen. Dieser definiert *wer bis wann was* tut. Die **Umsetzungskontrolle** (Follow-up) verifiziert später, ob die Massnahme effektiv war. Erst mit diesem nachweisbaren **Abschluss** ist der Audit-Zyklus beendet.

- **Beispiel Umsetzungskontrolle:** Um die kritische Feststellung des fehlenden Ransomware-Schutzes (aus dem vorherigen Beispiel) final zu beheben, lautet der Massnahmenplan: "Implementierung einer Object-Lock-Lösung auf dem Cloud-Storage bis zum 31. März".

Im April prüft der Auditor erneut (Follow-up-Audit). Er lässt sich im System zeigen, dass die Object-Lock-Funktion aktiviert ist und testet erfolgreich, dass ein modifizierter Backup-Block vom Storage abgelehnt wird. Die Massnahme wird als "geschlossen" markiert.

8. Compliance und regulatorische Anforderungen

Datensicherung ist heute keine rein technische Entscheidung mehr, sondern eine rechtliche Verpflichtung (Compliance). Das systematische Backup und Archivieren dient als fundamentaler **Compliance-Nachweis** (Folie 21).

8.1 Schweizer Datenschutzgesetz und Aufbewahrungsfristen

Das totalrevidierte **Schweizer Datenschutzgesetz (nDSG)**, das am 1. September 2023 in Kraft trat, stellt sehr hohe Anforderungen an die Datensicherheit (Integrität, Verfügbarkeit und Vertraulichkeit) bei der Verarbeitung von Personendaten. Backups sichern die Verfügbarkeit. Gleichzeitig regeln Gesetze wie das Obligationenrecht (OR) die zwingenden **Aufbewahrungsfristen** (z.B. die Geschäftsbücherverordnung GeBüV).

- **Beispiel Datenschutz vs. Aufbewahrung:** Eine Schweizer KMU muss einerseits nach OR Art. 958f Rechnungen 10 Jahre revisionssicher archivieren. Andererseits verlangt das nDSG, dass Personendaten gelöscht werden müssen, wenn der Zweck der Beschaffung entfallen ist (Auskunfts- und Löschrecht). Das Archivierungskonzept muss diese rechtliche Gratwanderung durchsetzen: Finanzdaten werden in ein unveränderbares WORM-Archiv für 10 Jahre verschoben, während das reine CRM-Marketing-Profil eines Kunden, der eine Löschung verlangt, sowohl aus dem produktiven System als auch aus den operativen Backups nachweislich entfernt wird.

8.2 Branchenregulierung

Zusätzlich zu allgemeinen Gesetzen unterliegen stark regulierte Sektoren spezifischen Vorgaben. In der **Branchenregulierung** setzen Organisationen wie die FINMA (Eidgenössische Finanzmarktaufsicht) im Banken- und Versicherungssektor strenge Massstäbe an das Business Continuity Management (BCM) und die Cyber-Resilienz. Krankenhäuser unterliegen kantonalen Gesundheitsgesetzen und dem KVG bezüglich der Patientenakten.

- **Beispiel Branchenregulierung:** Eine Schweizer Bank wird durch die FINMA (Rundschreiben 2008/21 "Operationelle Risiken - Banken", bzw. Nachfolger) auditiert. Die Bank muss nicht nur nachweisen, dass sie Backups hat, sondern dass sie ihre Kernbankensysteme innerhalb der definierten "Recovery Time Objective" (RTO) von beispielsweise 4 Stunden in einem komplett redundanten geografisch getrennten Ausweichrechenzentrum (Disaster Recovery Site) wieder hochfahren kann. Die Dokumentationen der durchgeführten Katastrophentests dienen hier als existenzieller Compliance-Nachweis gegenüber der Aufsichtsbehörde.

9. Fazit

Die in den Folien 14 bis 21 dargelegten Prinzipien zeigen deutlich, dass die Sicherstellung der Datenintegrität ein vielschichtiger, fortlaufender Prozess ist. Automatisierte Tools liefern die notwendige Effizienz im täglichen Betrieb, während manuelle Kontrollen, stringente Eskalationspfade und unerbittliche Audits die qualitative Güte der Systeme sichern. Insbesondere im Kontext strenger rechtlicher Rahmenbedingungen wie dem Schweizer Datenschutzgesetz wandelt sich das Backup- und Archivierungskonzept von einer reinen IT-Dienstleistung hin zu einem strategischen Instrument des Risikomanagements auf Stufe Geschäftsleitung. Unternehmen, die diesen ganzheitlichen Kontroll- und Prüfansatz (Plan-Do-Check-Act) rigoros leben, schützen nicht nur ihre Daten, sondern langfristig ihre Reputation und ihre rechtliche Handlungsfähigkeit.

Quellenverzeichnis

- **Primärquelle:** Polat, M. (o.J.). *Foliensatz: Kontrollen zur Sicherstellung der Funktion (Folien 14-17) & Prüfung der Konzeptinhaltung (Folien 18-21)*.
- **Bundesgesetzgebung (Schweiz):** * Bundesgesetz über den Datenschutz (Datenschutzgesetz, DSG) vom 25. September 2020 (Stand am 1. September 2023). SR 235.1.
 - Obligationenrecht (OR), insbesondere Art. 958f zur Aufbewahrung von Geschäftsbüchern. SR 220.
 - Verordnung über die Führung und Aufbewahrung der Geschäftsbücher (GeBüV). SR 221.431.
- **Standards und Best Practices (Implizit):**
 - ISO/IEC 27001:2022 - Informationssicherheits-Managementsysteme (ISMS) - Anforderungen (bezüglich Audit-Prozessen und Massnahmenplänen).
 - ITIL® 4 Framework (bezüglich Incident Management und Eskalationsprozessen).
 - FINMA-Rundschreiben zu Operationellen Risiken und Cyberrisiken (für branchenspezifische Beispiele in der Schweiz).